Sandbox y permisos en Codex

El sandbox acota lo que pueden hacer los procesos ejecutados por el agente.

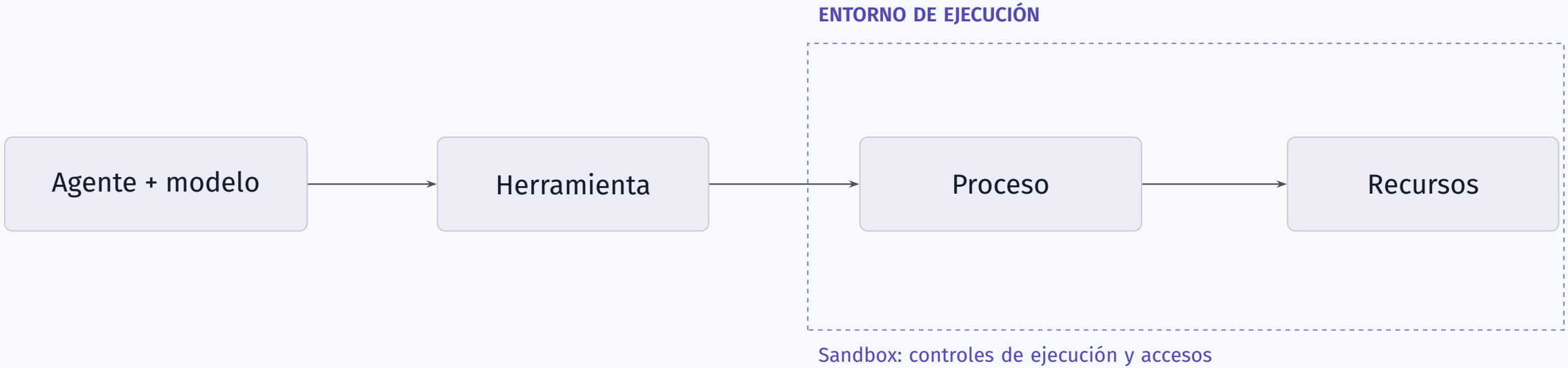
Permite avanzar por cuenta propia dentro de un alcance definido.



Política ilustrativa: lectura permitida y escritura externa restringida.

Quién decide, ejecuta y controla

El agente usa el modelo para decidir y solicita acciones mediante herramientas.



El modelo propone.
La herramienta inicia la acción.

El programa la intenta.
El sistema impone los límites.

Los programas lanzados heredan las restricciones aplicables a sus comandos.

Qué dimensiones se controlan

Un permiso depende del recurso y de la operación que se intenta realizar.

Lectura	Qué información puede consultar el proceso
Escritura	Qué archivos o ubicaciones puede modificar
Ejecución	Qué operaciones puede realizar un programa
Red	Qué conexiones puede realizar el comando

Leer un archivo no implica tener permiso para modificarlo.

Modos de sandbox

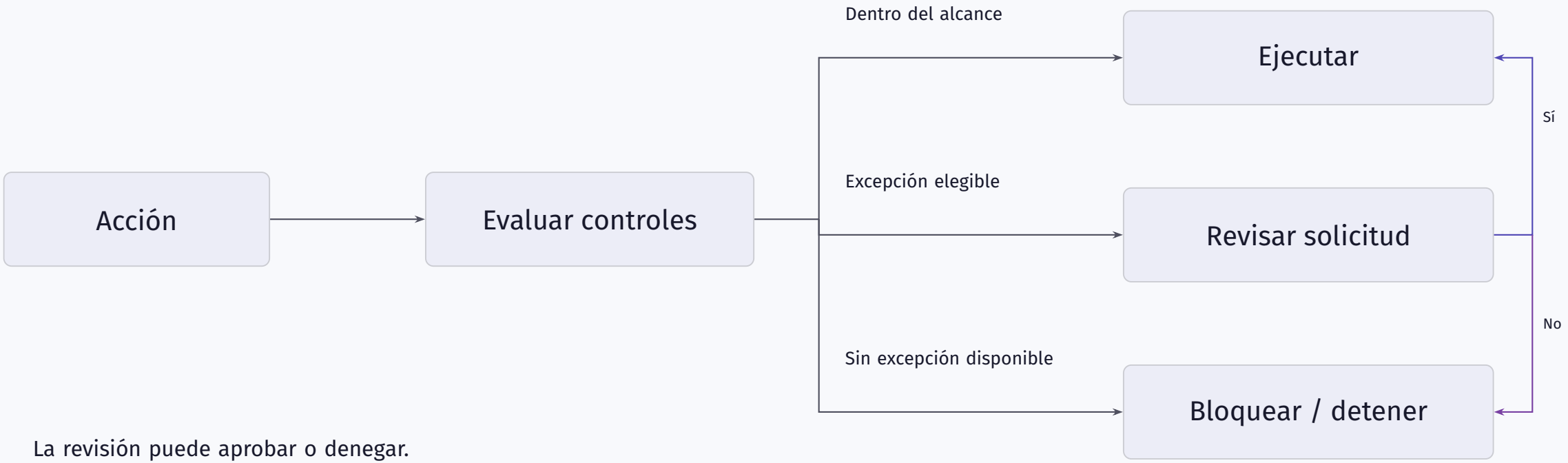
Definen el alcance inicial de la ejecución de comandos.

`read-only`	**Lectura bajo controles** Las escrituras quedan restringidas.
`workspace-write`	**Escritura en el proyecto** También en otras ubicaciones autorizadas.
`danger-full-access`	**Sin las fronteras del sandbox** Persisten los permisos del sistema.

Solo lectura puede permitir ejecutar programas que respeten sus límites.

Acción permitida, revisión o bloqueo

El alcance técnico y la política determinan cómo puede continuar una acción.

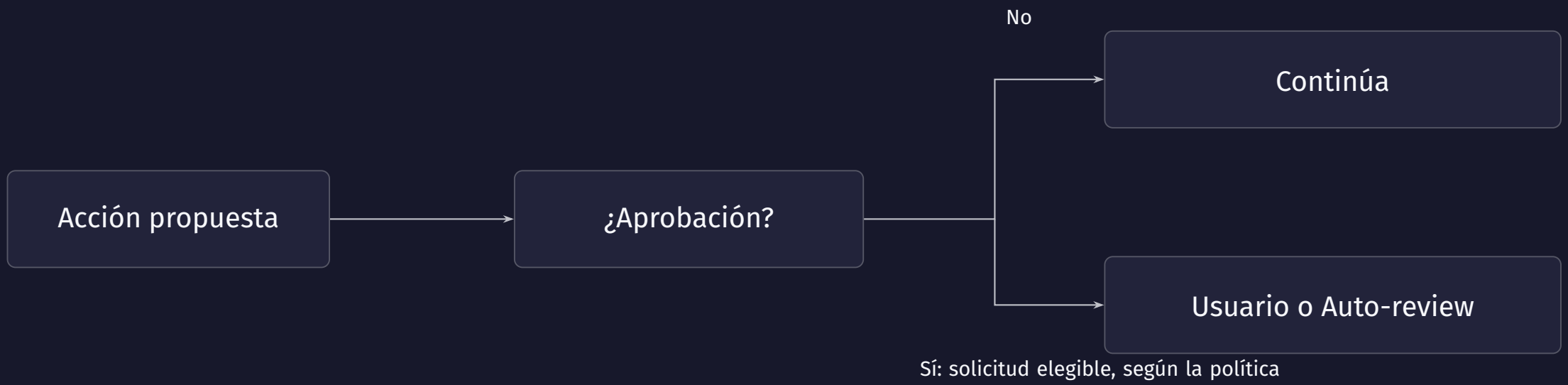


La revisión puede aprobar o denegar.
Una aprobación puede ampliar esa ejecución.

Una acción fuera del alcance no siempre tiene una excepción disponible.

Cuándo interviene Auto-review

Las acciones sin aprobación adicional continúan. Las solicitudes elegibles se revisan.



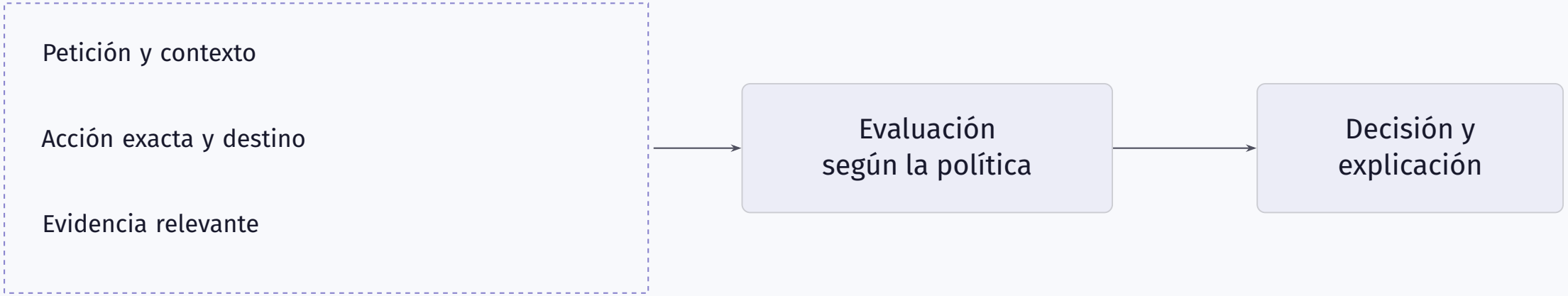
Ejemplo: escribir en `/ruta/entregas`, fuera del alcance actual.

La política debe permitir solicitar esa excepción. No se anticipa la decisión.

Auto-review evalúa solicitudes de aprobación elegibles.

Qué evalúa el revisor

Un agente separado evalúa la acción exacta con el contexto disponible.



¿Qué se hará? ¿Hay autorización? ¿Qué riesgos y efectos tiene?

Ejemplo: identificar la escritura solicitada y su carpeta de destino.

La revisión usa contexto y evidencia. No es una garantía infalible.

Qué ocurre después de la revisión

Aprobación y denegación son decisiones. Un timeout es un fallo técnico.

Aprobación	Puede continuar la acción con el alcance autorizado.
Denegación	Alternativa más segura o detenerse y consultar. No eludir el rechazo ejecutando lo mismo por otro camino.
Timeout Fallo técnico	La revisión no terminó a tiempo. Eso no demuestra que la acción sea insegura.

Aprobar esa acción no concede permisos generales para acciones futuras.

Auto-review puede equivocarse. Complementa al sandbox y a las políticas de la organización.

Configuración inicial explicada

`~/.codex/config.toml` guarda tus preferencias de inicio.

ejemplo-config.toml

```toml
sandbox_mode = "workspace-write"
approval_policy = "on-request"
approvals_reviewer = "user"

[sandbox_workspace_write]
writable_roots = []
network_access = false
```

sandbox_mode
Alcance técnico inicial.

approval_policy
Cuándo solicitar aprobación.

approvals_reviewer
Quién revisa las solicitudes.

Raíces y red
Accesos de los comandos.

Ejemplo didáctico. Su efecto está sujeto a la configuración y requisitos efectivos.

Cambiar una decisión de configuración

Cada comparación parte de la misma base. Solo cambia la línea señalada.

A. Cuándo solicitar aprobación

`approval_policy = "on-request"` → `approval_policy = "never"`

Se eliminan las solicitudes. El sandbox conserva sus límites.

B. Quién revisa, conservando on-request

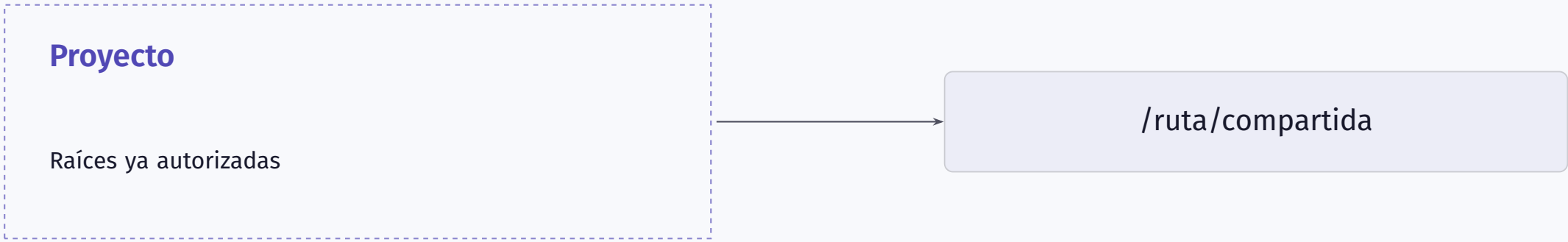
`approvals_reviewer = "user"` → `approvals_reviewer = "auto_review"`

Se delega la revisión elegible. No se amplían las carpetas por ese cambio.

Son variantes independientes. Con never no hay solicitudes que auto-review pueda revisar.

Alcance de escritura

writable_roots añade ubicaciones de escritura al modo workspace-write.




```
writable_roots = []
```

```
writable_roots = ["/ruta/compartida"]
```

Cambia solo la carpeta adicional. La política de aprobación y la red se conservan.

Ruta ficticia. Añadir escritura no define por sí solo todo el alcance de lectura.

Acceso de red

Habilitar conexiones de comandos es distinto de permitir escritura.

Red deshabilitada

`network_access = false`

El comando no recibe
acceso saliente de red.

Red habilitada

`network_access = true`

Puede usar red según
los controles efectivos.

Ejemplo: descargar una dependencia. El destino puede requerir filtros o autenticación.

Este ajuste no define los permisos de todos los navegadores y conectores.

El lugar de ejecución importa

Una tarea puede combinar pasos locales y pasos en la nube.

Computadora conectada

Un programa accede a archivos del equipo.

Se aplican los controles locales de ejecución.

Entorno cloud

Un navegador alojado accede a una web.

Se aplican los controles de ese entorno.

El orquestador coordina la tarea. Cada ejecución tiene su propio alcance.

Un permiso o restricción local no se transfiere automáticamente a cloud.

Qué controla el sandbox y qué debes revisar

Una acción puede estar dentro de los permisos y aun así ser incorrecta.

Política ilustrativa: escritura solo en `/proyecto`, sin excepciones.

/proyecto: escritura permitida

Modificar el documento equivocado

Dentro del alcance. Cambio incorrecto.

Guardar información falsa

Dentro del alcance. Contenido por verificar.



Escribir en otra carpeta

Fuera del alcance.
La escritura queda bloqueada.

El sandbox limita el acceso. Revisa también qué cambió y si cumple lo solicitado.

Una tarea, dos revisores

Misma tarea y sandbox solicitado. Cambia quién revisa la solicitud para exportar.

REVISIÓN MANUAL

4 intervenciones humanas

3 previas y 1 para exportar

AUTO-REVIEW

0 intervenciones humanas

Confirmado por el usuario

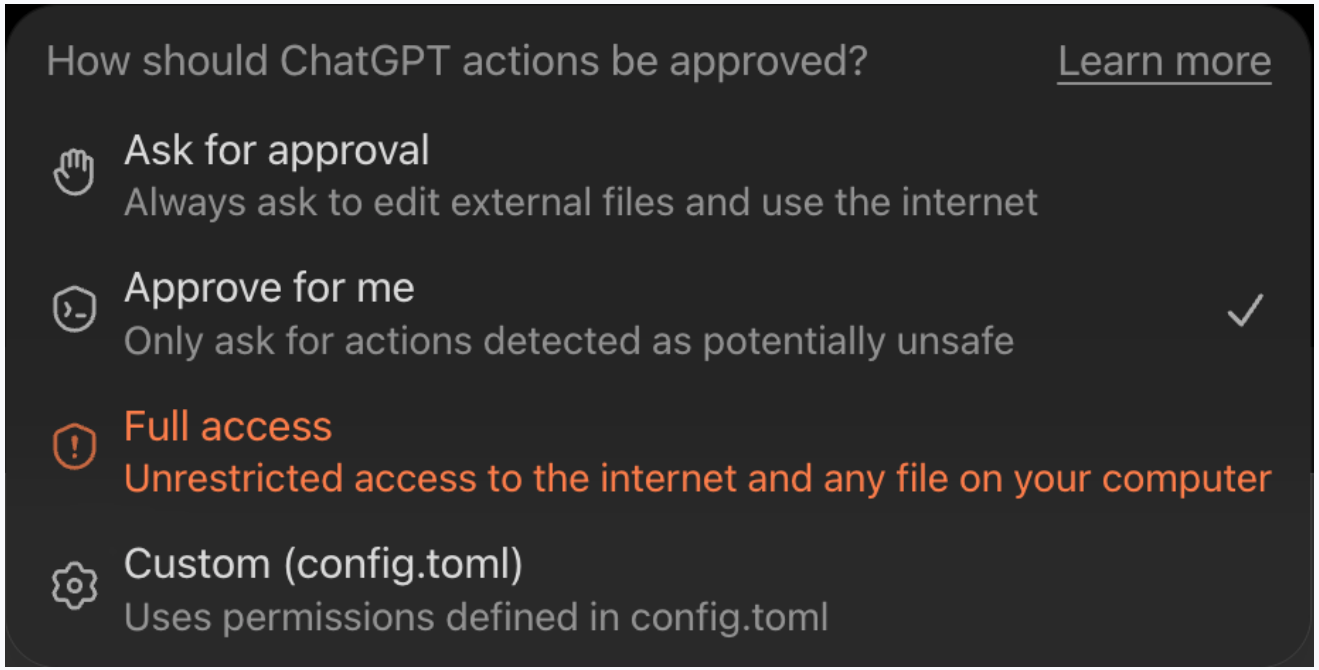
Resultado verificado	Manual	Auto-review
Evaluación y copia exportada	6 de 6 y copia	6 de 6 y copia

Una pasada por modo. El resumen no identifica decisiones automáticas individuales.

Ambas tareas completadas. Exportar fuera del alcance requiere una solicitud elegible.

Del concepto al selector de la app

Apoyo: las opciones de interfaz combinan controles que ya conoces.



Ask for approval
Revisión humana.

Approve for me
Revisión automática elegible.

Full access
Sin fronteras del sandbox ni prompts.

Custom
Configuración personalizada.

Captura del usuario. Opciones sujetas a cliente, cuenta y políticas.

Preferencias dentro de límites obligatorios

Tú eliges cómo empezar. La empresa limita qué opciones puedes elegir.

Tu preferencia

`config.toml`

```
sandbox_mode = "workspace-write"
approval_policy = "on-request"
```

Escribir dentro del proyecto.
Pedir aprobación para una excepción.

Regla de la empresa

`requirements.toml`

```
allowed_sandbox_modes = [
  "read-only",
  "workspace-write"
]
```

La empresa admite solo esos dos modos.

`workspace-write` o `read-only`	Compatibles con esta regla.
`danger-full-access`	No se admite como opción permitida.

Tu preferencia debe estar dentro de las opciones que permite la empresa.

Ejemplo con modos tradicionales. Para clientes recientes, OpenAI recomienda perfiles de permisos.